SKITII ADMIN PLATFORM

7-Day Task List

User management, roles and module permissions, a common sidebar for Product Admin and Trial Admin, and audit history.

VERSION
1.0

DATE
August 2026

AUTHOR
Swapnil Sagvekar

CUSTOMER
Internal (Skitii Admin + Trial Admin)

SCOPE
User Management, Roles & Module Permissions, Common Sidebar, Audit History

Goal for Day 7

By end of Day 7:

- **Super Admin / Admin** can create and manage internal users and roles in **Skitii Product Admin** (backed by **Skitii Backend**)
- Each role has a **module permission matrix**: View / Create / Edit / Delete
- **One common sidebar pattern** for Product Admin and Trial Admin — items appear only if the user has **View** on that module
- Screens and APIs honour Create / Edit / Delete (buttons hidden; GraphQL/REST rejected)
- **Audit history** records who added, edited, or deleted users, roles, permissions, and key admin records
- Both admin panels login with the same Product Backend OTP → JWT; Trial Backend enforces the same permission keys

---

Current state (must change)

Area	Today	After this sprint
Roles	`ADMIN`, `INSTITUTION`, `CLINICAL_VALIDATION` only	Add `SUPER_ADMIN`; keep hospital roles; add **custom admin roles**
User management	Institution approve / reject / block only; admin users are **seeded**	Users module: list / create / edit / assign role / block
Permissions	Whole-app `ADMIN` gate	Per-module `view` · `create` · `edit` · `delete`
Sidebar	Two static copies, all items always shown	Shared catalog, filtered by `view`
Audit	`createdAt` / `updatedAt` only	`auditLogs` with actor, action, module, before / after

Hospital / tablet accounts (`INSTITUTION`, `CLINICAL_VALIDATION`) stay as **system roles**. This sprint is for **Skitii internal admin users** of the two web panels.

Overview

Days	Workstream	Duration
1	RBAC schema, module catalog, Super Admin seed	1 day
2	User management APIs (Product Backend)	1 day
3	Roles + permission matrix APIs + resolver guards	1 day
4	Product Admin UI — Users & Roles	1 day
5	Common sidebar + Product Admin enforcement	1 day
6	Trial Admin sidebar + Trial Backend enforcement	1 day
7	Audit log (API + UI) + smoke + handoff	1 day

> Product Backend is the **source of truth**. Both admin panels read `me { roles, permissions }`. Trial Backend must **not** invent a second permission store.

Permission model

Actions (every module)

Action	Meaning in UI	Meaning on API
view	Sidebar item + list/detail	Query / GET
create	Add / New button	Create mutation
edit	Edit / Save / status change	Update mutation
delete	Delete / archive / deactivate	Delete or destructive mutation

Missing **view** → module hidden. Missing **create** / **edit** / **delete** → control hidden **and** API returns `FORBIDDEN`.

Roles

Role	Who	Powers
SUPER_ADMIN	Seeded Skitii owner	All modules, all actions. Can create Admins and custom roles. Cannot be blocked or demoted by a non–Super Admin
ADMIN	Existing internal role	Powers = assigned matrix. May manage users **except** Super Admins, if given the Users module
Custom roles	e.g. Music Manager, Content Manager, Trial Operator	Matrix only — no implicit full access
`INSTITUTION` / `CLINICAL_VALIDATION`	System	Unchanged; not editable in this UI

Module catalog (sidebar keys)

Product Admin (`product`)

Key	Sidebar
`product.dashboard`	Dashboard
`product.institutions`	Institutions
`product.devices`	Physical Devices
`product.patients`	Patients
`product.sessions`	Sessions
`product.music_categories`	Music Categories
`product.music_library`	Music Library
`product.email_categories`	Email Template Categories
`product.email_templates`	Email Templates
`product.inquiries`	Inquiries
`product.blog_topics`	Blog Topic
`product.blogs`	Blogs
`product.podcast_topics`	Podcast Topic
`product.podcasts`	Podcasts
`product.episodes`	Episodes
`product.users`	User Management *(new)*
`product.roles`	Roles & Permissions *(new)*
`product.audit`	Audit History *(new)*

Trial Admin (`trial`)

Key	Sidebar
`trial.dashboard`	Dashboard
`trial.trials`	Trials
`trial.institutions`	Institutions
`trial.configurations`	Configurations
`trial.patients`	Patients
`trial.sessions`	Sessions
`trial.statistics`	Session Statistics
`trial.weekly_statistics`	Weekly Statistics
`trial.music`	Music

A user may have Product modules, Trial modules, or both. Login is the same OTP; each panel only renders its own panel's keys.

Days 1 — Schema, catalog, Super Admin

Stream	Tasks	Status
Backend	Add `SUPER_ADMIN` to `Role`. Collections: `adminRoles` (name, isSystem, panel), `adminRolePermissions` (roleId, moduleKey, view/create/edit/delete), `auditLogs` (stub schema). Seed module catalog for product + trial keys. Seed one Super Admin with full matrix. JWT still carries `roles[]`; permissions loaded per request (do not stuff the full matrix into the token)	☐
Contract	Document `me` payload: `{ id, email, roles, permissions: { [moduleKey]: { view, create, edit, delete } } }`	☐

Deliverable: Super Admin can authenticate; `me` returns a full permission map. No UI yet.

Day 2 — User management APIs (Product Backend)

Stream	Tasks	Status
Backend	GraphQL: list users (search, role, status, pagination); get user; create internal admin user (email + roleIds); update; assign/replace roles; block/unblock. Default status `APPROVED` + `isVerified` for admin-created users (OTP login unchanged)	☐
Rules	Only Super Admin can create / edit / block Super Admins. Admin cannot escalate to Super Admin. Last Super Admin cannot be blocked. `@Roles` + new permission check on `product.users`	☐

Deliverable: Users CRUD ready for the Product Admin screen. Institution signup flow unchanged.

Day 3 — Roles, matrix APIs, API guards

Stream	Tasks	Status
Backend	GraphQL: list / create / update / archive custom roles; get/set permission matrix (module × 4 actions). System roles (`SUPER_ADMIN` , `INSTITUTION` , `CLINICAL_VALIDATION`) are view-only	☐
Guards	`PermissionsGuard` (moduleKey + action) on Product Backend admin resolvers. Map existing modules (institutions, music, sessions, …) to catalog keys. Super Admin bypasses the matrix	☐
me	`me` / `myPermissions` used by both admin panels after login	☐

Deliverable: Changing a role's matrix immediately changes what APIs that user can call.

Day 4 — Product Admin UI: Users & Roles

Stream	Tasks	Status
Frontend (Product)	**Users** — list, search, filters, add, edit, assign role(s), block. **Roles** — list; permission matrix (grouped by Product / Trial panels); save. Super Admin badge; disable dangerous actions in UI to match Day 2 rules	☐
API client	RTK/GraphQL endpoints for users, roles, `me`	☐

Deliverable: Super Admin can create an "Admin" or custom role, tick modules, and log in as that user to see the difference (sidebar still static until Day 5).

Day 5 — Common sidebar + Product Admin enforcement

Stream	Tasks	Status
Shared pattern	Extract a **permission-aware sidebar**: same item shape (`key` , `title` , `path` , `icon` , optional `children` / `section`). Filter: show item if `permissions[key].view` . Shared helpers: `can(module, action)` , route guard, hide Create/Edit/Delete buttons	☐
Product Admin	Replace static `menuConfig` with catalog + `me` . Add Users / Roles / Audit (Audit page can be a shell until Day 7). Deep links to hidden modules redirect	☐
Backend	Confirm Product mutations already return `FORBIDDEN` when action is missing (Day 3)	☐

Deliverable: Two Product Admin users with different matrices see different sidebars and cannot cheat via URL.

Common sidebar (not a third repo unless already shared): same component contract in both Next apps — copy-aligned `menuConfig` driven by **module keys from backend**, not two unrelated trees. Do not keep a hard-coded always-visible menu.

Day 6 — Trial Admin + Trial Backend enforcement

Stream	Tasks	Status
Trial Admin	After OTP, call Product `me` . Apply the **same sidebar filter** to Trial `menuSections` (`trial.*` keys only). Hide/disable Create/Edit on Trials, Configurations, Patients per matrix. Scope bar unchanged	☐
Trial Backend	On admin GraphQL, load user from Auth DB + permission map from Product collections (or Product-backed helper). `AdminGuard` + `PermissionsGuard` using `trial.*` keys (e.g. `createAdminTrial` needs `trial.trials` + **create**). Institute tablet APIs unchanged	☐

Deliverable: A “Trial Operator” role with view-only Patients/Sessions never sees Setup or Music, and cannot mutate trials.

Day 7 — Audit history, polish, handoff

Stream	Tasks	Status
Backend	Write `auditLogs` on: user create/update/block, role create/update, permission matrix save, and mapped admin CRUD (institution approve/block, trial create/update — at least user/role/permission in v1; extend module writes as time allows). Fields: `actorUserId`, `actorEmail`, `action`, `moduleKey`, `entityType`, `entityId`, `before`, `after`, `ip`, `createdAt`. List API with filters (actor, module, action, date) — requires `product.audit` **view**	☐
Frontend (Product)	Audit page: table + filters + before/after detail dialog. Read-only	☐
Both panels	Loading / empty / forbidden states. Smoke: Super Admin vs limited Admin vs Trial-only role on **both** URLs	☐

Handoff checklist

- ☐ Super Admin logs into Product Admin → sees Users, Roles, Audit
- ☐ Create custom role with a subset of Product + Trial modules
- ☐ Create user, assign that role, login — sidebar matches matrix
- ☐ Same user on Trial Admin — only `trial.*` view items show
- ☐ Create/Edit/Delete buttons hidden when not granted; API returns `FORBIDDEN` if called anyway
- ☐ Super Admin cannot be blocked by a regular Admin
- ☐ Audit shows who changed the user and who saved the matrix
- ☐ Institution / tablet login still works (no regression)

Deliverable: User management, common permission sidebar, and audit history ready for UAT.

Parallel Work View (Days 1–7)

```
Day:     1         2         3          4         5          6          7
         |
Backend  [Schema+seed] [Users API] [Roles+guards]           [Trial enforce] [Audit API]
Product FE                       [Users+Roles UI] [Common sidebar]
Trial FE                                    [Sidebar+ACL]
```

What this 7-day sprint is not

Out of scope	Note
Institution self-signup / approve / credits	Existing Institution Management stays
Tablet / HNF app roles	Unchanged
Rebuilding Trial Admin clinical screens	Only gate them
Full audit of every clinical row (sessions, weekly forms)	v1 = users, roles, permissions + as many admin writes as time allows
Separate identity provider / SSO	OTP + JWT stays

Checkpoint Summary

Checkpoint	Day	Expected outcome
Model ready	Day 1	Super Admin + module catalog + `me`
Users API	Day 2	Create / assign / block internal users
ACL on APIs	Day 3	Matrix enforced on Product GraphQL
Admin can operate	Day 4	Users & Roles screens in Product Admin
Product sidebar	Day 5	Menu and buttons follow permissions
Trial sidebar	Day 6	Same ACL on Trial Admin + Trial Backend
Audit complete	Day 7	History UI + smoke on both panels

Risks for 7 Days

Risk	Mitigation
Permission checks missed on some resolvers	Day 3: central `PermissionsGuard`; Day 7 smoke with a least-privilege user
Two sidebars drift	One module-key catalog in backend; both FEs only map key → path/icon
JWT too large if matrix is embedded	Load permissions server-side per request; `me` is a query, not a token claim dump
Trial Backend cannot read Product collections	Day 6: shared Auth DB already used for users; permissions live next to users or via an internal Product query
7 days too tight for full clinical audit	Ship user/role/permission audit as must-have; other modules as stretch on Day 7

Stretch (only if Days 1–6 are green)

Item	Note
Audit of trial create/update and institution approve/block	Same `auditLogs` writer
Permission presets (“clone role”)	Speeds Super Admin setup
Export audit CSV	Filter then download